API Autentikasi Customer — Web Frontend

Dokumen ini hanya mencakup autentikasi customer/member untuk website marketplace Walatra Herbal. Login menggunakan OTP nomor WhatsApp; login email dan password tidak digunakan untuk customer.

Konfigurasi dasar

```
Base URL: http://103.247.8.168/api/v1
Content-Type: application/json
Accept: application/json
```

Untuk endpoint yang membutuhkan login, kirim token pada setiap request:

```
Authorization: Bearer {token}
```

Flow utama

```
Masukkan nomor WhatsApp
→ request OTP
→ user menerima OTP
→ verifikasi OTP
→ simpan token
→ cek profil
→ lengkapi nama jika diperlukan
→ user dapat mengakses fitur member
```

1. Meminta OTP

```
POST /auth/customer/request-otp
```

Request:

```
{
    "phone": "081234567890"
}
```

Aturan:

- `phone` wajib berupa nomor WhatsApp yang valid.

- Nomor boleh dikirim dalam format `08...` atau format internasional yang didukung sistem.
- OTP berlaku selama 5 menit.
- Meminta OTP baru akan membatalkan OTP sebelumnya.
- Endpoint memiliki rate limit. Frontend harus menangani HTTP `429` dan tidak melakukan retry otomatis secara agresif.

Response sukses:

```
{
    "success": true,
    "code": "OTP_REQUESTED",
    "message": "OTP sedang diproses. Silakan periksa WhatsApp Anda.",
    "data": {
        "challenge_id": 123,
        "expires_at": "2026-10-30T15:05:00+07:00",
        "delivery_status": "pending"
    }
}
```

Nilai `delivery_status` dapat berupa:

- `pending`: job pengiriman sedang diproses.
- `sent`: OTP berhasil dikirim provider.
- `failed`: pengiriman gagal.
- `unknown`: status provider belum dapat dipastikan.
- `skipped`: provider OTP tidak aktif pada environment tersebut.

Field `data.otp` hanya dapat muncul pada environment lokal/testing jika konfigurasi expose OTP diaktifkan. Frontend production tidak boleh bergantung pada field tersebut.

2. Verifikasi OTP dan login

```
POST /auth/customer/verify-otp
```

Request:

```
{
    "phone": "081234567890",
    "challenge_id": 123,
    "otp": "123456",
    "device_name": "web-chrome"
}
```

Aturan:

- `challenge_id` berasal dari response request OTP.

- `otp` harus terdiri dari 6 digit.
- `device_name` wajib, maksimal 100 karakter.
- Maksimal percobaan verifikasi mengikuti konfigurasi server.

Response sukses untuk user baru maupun user lama:

```
{
    "success": true,
    "code": "AUTHENTICATED",
    "message": "Login berhasil.",
    "data": {
        "user": {
            "id": 10,
            "name": null,
            "phone": "628123456789",
            "profile_completed_at": null
        },
        "token": "1|token-rahasia",
        "token_type": "Bearer",
        "is_new_user": true,
        "requires_profile_completion": true
    }
}
```

Jika nomor belum terdaftar, sistem membuat akun customer secara otomatis. Jika sudah terdaftar, sistem menggunakan akun yang sama dan tidak membuat akun duplikat.

Frontend menyimpan token secara aman. Untuk aplikasi web, utamakan mekanisme cookie `HttpOnly`, `Secure`, dan `SameSite` yang dikelola oleh backend. Jika frontend menggunakan Bearer token secara langsung, jangan menaruh token di URL, log, atau source code.

3. Mengambil sesi user aktif

```
GET /auth/me
Authorization: Bearer {token}
```

Response:

```
{
    "success": true,
    "message": "User aktif.",
    "code": "AUTHENTICATED",
    "data": {
        "user": {
            "id": 10,
            "name": "Budi Walatra",
            "email": null,
```

```
            "phone": "628123456789",
            "profile_completed_at": "2026-10-30T15:10:00+07:00"
        },
        "requires_profile_completion": false
    }
}
```

Frontend sebaiknya memanggil endpoint ini ketika aplikasi dibuka kembali untuk memastikan token masih valid dan akun masih aktif.

4. Melengkapi profil customer

User baru wajib melengkapi nama sebelum melanjutkan flow yang membutuhkan profil lengkap.

```
PATCH /auth/customer/profile
Authorization: Bearer {token}
```

Request:

```
{
    "name": "Budi Walatra"
}
```

Aturan `name`:

- wajib diisi,
- minimal 2 karakter,
- maksimal 255 karakter.

Response sukses:

```
{
    "success": true,
    "message": "Profil berhasil dilengkapi.",
    "code": "PROFILE_UPDATED",
    "data": {
        "user": {
            "id": 10,
            "name": "Budi Walatra",
            "email": null,
            "phone": "628123456789",
            "profile_completed_at": "2026-10-30T15:10:00+07:00"
        },
        "requires_profile_completion": false
    }
}
```

5. Logout

```
POST /auth/logout
Authorization: Bearer {token}
```

Response:

```
{
    "success": true,
    "message": "Logout berhasil.",
    "data": null
}
```

Logout hanya mencabut token pada device/session yang sedang digunakan.

Endpoint lama yang tidak digunakan

```
POST /auth/login
```

Endpoint tersebut tidak melakukan login password dan mengembalikan HTTP `410` dengan code `OTP_ONLY_AUTHENTICATION`. Frontend harus menggunakan flow OTP.

Penanganan error frontend

Nomor tidak valid — HTTP 422

```
{
    "message": "The phone field is invalid.",
    "errors": {
        "phone": ["Format nomor WhatsApp tidak valid."]
    }
}
```

OTP salah atau kedaluwarsa — HTTP 422

```
{
    "message": "The otp is invalid.",
    "errors": {
        "otp": ["OTP tidak valid atau sudah tidak dapat digunakan."]
    }
}
```

Token tidak ada atau sudah dicabut — HTTP 401

Frontend harus menghapus session lokal dan mengarahkan user kembali ke halaman login.

Akun tidak aktif atau token tidak memiliki ability — HTTP 403

Frontend menampilkan pesan bahwa akun tidak dapat mengakses marketplace dan tidak melakukan retry token secara terus-menerus.

Terlalu banyak request — HTTP 429

Frontend menampilkan countdown berdasarkan header `Retry-After` jika tersedia, kemudian mengaktifkan kembali tombol kirim OTP setelah waktunya selesai.

Catatan implementasi web

1. Nonaktifkan tombol kirim OTP selama request berlangsung.
2. Simpan `challenge_id` hanya selama proses verifikasi OTP.
3. Jangan menampilkan OTP dari response pada production.
4. Setelah login, panggil `/auth/me` untuk mengisi state user.
5. Jika `requires_profile_completion` bernilai `true`, arahkan ke form nama.
6. Hapus token ketika logout atau menerima HTTP `401`.
7. Jangan melakukan retry otomatis untuk HTTP `401`, `403`, atau `429` tanpa aturan yang sesuai.